

Analisi del Contesto e Valutazione dei Rischi

Analisi del business

Asset critici:

- codice sorgente
- modelli di AI
- dati dei clienti che alimentano AI, fornitori, partner, dipendenti. DB
- infrastruttura di sviluppo
- infrastruttura di rete:
 - AWS: VPC (ACL e security group), DB, VM,
 - DMZ e frammentazione della rete (2 subnet), WIFI mesh con tre access point
- documentazione tecnica
- Log di sistema e di rete: registri delle attività sui server, sulle workstation e sulla rete aziendale.

Processi aziendali chiave:

- software engineering
- cloud engineering
- AI training (distillation)
- AI agent developing
- AI consultant

Requisiti legali, regolamentari e contrattuali

IDENTIFICAZIONE:

- dati trattati:
 - dati comuni
 - categorie particolari di dati personali
 - dati penali
 - dati che presentano rischi elevati In base alla particolarità dei dati trattati viene applicata una policy specifica per il loro trattamento e smaltimento.
- sistemi di AI che sviluppiamo:
 - alto rischio (dati sanitari per esempio)
 - medio rischio
 - basso rischio
- accordi di non divulgazione con partner e fornitori

Attacchi specifici

- furto di proprietà intellettuale
- attacchi alla supply chain
- insider threat (**Prompt injection**)
- jailbreaking
- DDoS
- Injection
- Data poisoning
- Zero day

Valutazione del rischio

Rischio intrinseco

- Codice sorgente: impatto 6 probabilità 3
- Modelli di AI: impatto 4 probabilità 4

- dati clienti che alimentano ai (comuni): impatto 2 probabilità 3
- dati clienti che alimentano ai (rischio elevato): impatto 7 probabilità 4
- infrastruttura di sviluppo: impatto 4 probabilità 4
- infrastruttura di rete: impatto 6 probabilità 3
- documentazione tecnica: impatto 6 probabilità 3
- log di sistema: impatto 5 probabilità 4

Rischio intrinseco:

- codice sorgente: 18
- modelli AI: 16
- dati clienti che alimentano ai (comuni): 6
- dati clienti che alimentano ai (rischio elevato): 28
- infrastruttura di sviluppo: 16
- infrastruttura di rete: 18
- documentazione tecnica: 18
- log di sistema: 20

Misure di mitigazione

- codice sorgente: cifratura del disco, DC che gestisce la granularità dei permessi.
- modelli AI: hardening del codice, gestione degli accessi su Git, attacchi programmati penetration test, alert di monitoraggio per DDoS, audit e data sanitization, gestione periodica delle patch.
- dati clienti che alimentano ai (comuni): cifratura del disco, frammentazione dei dati, DC che gestisce la granularità dei permessi, audit e data sanitization.
- dati clienti che alimentano ai (rischio elevato): cifratura del disco, frammentazione dei dati, DC che gestisce la granularità dei permessi, audit e data sanitization.
- infrastruttura di sviluppo: stratificazione di rete, DC che gestisce la granularità dei permessi, aggiornamenti del sw.
- infrastruttura di rete: uso di firewall, stratificazione di rete, gestione degli aggiornamenti sw e hw.
- documentazione tecnica: cifratura del disco, DC che gestisce la granularità dei permessi.
- log di sistema: DC che gestisce la granularità dei permessi, sistema di monitoraggio (alert).

Rischio residuo:

- Codice sorgente: impatto 3 probabilità 2
- Modelli di AI: impatto 4 probabilità 2
- dati clienti che alimentano ai (comuni): impatto 1 probabilità 2
- dati clienti che alimentano ai (rischio elevato): impatto 3 probabilità 2
- infrastruttura di sviluppo: impatto 4 probabilità 2
- infrastruttura di rete: impatto 6 probabilità 3
- documentazione tecnica: impatto 6 probabilità 3
- log di sistema: impatto 5 probabilità 3

Rischio Residuo:

- Codice sorgente: 6
- Modelli di AI: 8
- dati clienti che alimentano ai (comuni): 2
- dati clienti che alimentano ai (rischio elevato): 6
- infrastruttura di sviluppo: 8
- infrastruttura di rete: 18
- documentazione tecnica: 18
- log di sistema: 15

Area	Attacchi	Probabilità (Intrinseco)	Impatto (Intrinseco)	Rischio Intrinseco	Contromisure	Probabilità (Residuo)	Impatto (Residuo)	Rischio Residuo
------	----------	-----------------------------	-------------------------	-----------------------	--------------	--------------------------	----------------------	--------------------

Area	Attacchi	Probabilità (Intrinseco)	Impatto (Intrinseco)	Rischio Intrinseco	Contromisure	Probabilità (Residuo)	Impatto (Residuo)	Rischio Residuo
1. Codice sorgente	Data Breach, furto di proprietà intellettuale, ramsowere	3	6	18	cifratura del disco, DC che gestisce la granularità dei permessi.	2	3	6
2. modelli AI	Attacchi DDoS, threat (Prompt injection), Data poisoning	4	4	16	hardening del codice, gestione degli accessi su Git, attacchi programmati penetration test, alert di monitoraggio per DDoS, audit e data sanitization, gestione periodica delle patch.	2	4	8
3. dati clienti che alimentano ai (comuni)	Data Breach, Data poisoning, furto di proprietà intellettuale, ramsowere	3	2	6	cifratura del disco, frammentazione dei dati, DC che gestisce la granularità dei permessi, audit e data sanitization.	2	1	2
4. dati clienti che alimentano ai (rischio elevato)	Data Breach, Data poisoning, furto di proprietà intellettuale, ramsowere	4	7	28	cifratura del disco, frammentazione dei dati, DC che gestisce la granularità dei permessi, audit e data sanitization.	2	3	6
5. infrastruttura di sviluppo	threat (Prompt injection), Data poisoning	4	4	16	stratificazione di rete, DC che gestisce la granularità dei permessi, aggiornamenti del sw.	2	4	8
6. infrastruttura di rete	DDoS, Phishing, Sniffing	3	6	18	uso di firewall, stratificazione di rete, gestione degli aggiornamenti sw e hw.	3	6	18

Area	Attacchi	Probabilità (Intrinseco)	Impatto (Intrinseco)	Rischio Intrinseco	Contromisure	Probabilità (Residuo)	Impatto (Residuo)	Rischio Residuo
7. documentazione tecnica	Data Breach, furto di proprietà intellettuale	3	6	18	cifratura del disco, DC che gestisce la granularità dei permessi.	3	6	18
8. log di sistema	Data Breach, furto di proprietà intellettuale, ransower, log tampering	4	5	20	DC che gestisce la granularità dei permessi, sistema di monitoraggio (alert).	3	5	15

PROBABILITÀ	7	7	14	21	28	35	42	49
	6	6	12	18	24	30	36	42
	5	5	10	15	20	25	30	35
	4	4	8	12	16	20	24	28
	3	3	6	9	12	15	18	21
	2	2	4	6	8	10	12	14
	1	1	2	3	4	5	6	7
	x	1	2	3	4	5	6	7
IMPATTO								

1-12	Accettabile
13-25	Basso
26-38	Medio
39-49	alto

avanti